Note de sécurité — FasoMsg

Sprint technique pré-hackathon · Hackathon 226 – Édition 2026 · Socle de sécurité « obligatoire » — Équipe : [Nom de l'équipe] · [Membre 1], [Membre 2], [Membre 3]

1. Menaces prises en compte et protections.

Menace	Protection en place
Écoute passive du réseau	Tout transite chiffré E2E ; contenu illisible même sur le serveur (Olm/Megolm, AES-GCM pour les fichiers). En production, TLS en terminaison sur le reverse-proxy de l'État.
Serveur compromis (lecture de la base)	Aucun clair stocké : enveloppes Megolm, blobs AES-GCM, clés publiques seulement. Outil d'audit : scripts/inspecter_db.js.
Intrus non enrôlé / usurpation	Enrôlement par code nominatif à usage unique (haché en base) ; inscription impossible sans code ; second facteur TOTP (RFC 6238) ; scrypt + sel, comparaison à temps constant.
Force brute sur les identifiants	Blocage 5 échecs / 15 min par identifiant ; TOTP à un million de combinaisons, fenêtre d'une seule période.
Vol ou départ d'un agent	Révocation immédiate : sessions détruites, connexion refusée, retrait de tous les salons, rotation Megolm (epoch) : plus aucune nouvelle clé distribuée ; effacement local à distance (événement WebSocket « revocation »).
Fuite de session (vol de cookie)	Cookie HttpOnly + SameSite=Strict ; la base ne stocke que sha256(jeton) ; sessions expirées purgées ; révocation = invalidation immédiate.
Falsification ou rejeu des clés de salon	Chaque clé de salon est signée ed25519 par l'appareil émetteur et vérifiée contre l'annuaire des clés publiques ; clés jetables consommées une seule fois ; messages pré-clés non rejouables.
Injection web (XSS, clics piégés)	Échappement HTML systématique, CSP stricte (self, aucun script externe), X-Frame-Options DENY, SQL exclusivement préparé.
Diffusion non maîtrisée des notes sensibles	Classification : expiration automatique (suppression serveur), filigrane nominatif, copie bloquée, absence de fonction de transfert.
Compromission d'un appareil ancien	Clés jetables : forward secrecy des sessions Olm ; rotation Megolm borne la portée des anciennes clés de salon au passé du salon.

2. Ce que le serveur voit malgré tout (métadonnées) et mesures de minimisation. Honnêtement, un serveur de messagerie E2EE conserve des métadonnées. FasoMsg expose : **qui échange avec qui** (membres des salons, conversations directes), **quand** (horodatages des envois et connexions), **quelle taille** (messages, fichiers), **l'expiration** (horodatage TTL, sans libellé de classification : celui-ci est chiffré), l'identité administrative des agents (annuaire, par conception) et les clés **publiques** des appareils. Minimisation : aucun contenu, objet ou libellé en clair ; TTL courts pour les messages classés (30 min à 7 jours, purge automatique) ; le serveur ne peut relire ni reconstruire les conversations passées (clés absentes) ; journal d'audit consultable par l'administrateur. Une analyse de trafic temporel ou par taille reste théoriquement possible — limite assumée, commune aux messageries E2EE centralisées.

3. Limites connues.

1. vérification des clés manuelle : l'empreinte ed25519 est affichée (écran Profil) mais sans comparaison interactive croisée (emoji/QR) — extension prioritaire ;

2. appareil compromis après déchiffrement : un agent malveillant peut photographier ou exporter un message déjà déchiffré ; le filigrane nominatif en dissuade la diffusion et l'expiration en borne la durée (limite fondamentale de tout E2EE) ;

3. révocation et historique local : l'effacement local est déclenché à distance dès reconnexion ; si l'agent ne se reconnecte jamais, son stockage antérieur reste sur son appareil ;

4. client honnête : expiration et blocage de copie sont appliqués par notre client ; un client falsifié peut les ignorer — en revanche la rotation Megolm protège cryptographiquement les messages futurs ;

5. rattrapage hors ligne : la file « to-device » est plafonnée (300 messages) ; un appareil trop longtemps hors ligne doit republier des clés jetables ;

6. interface mooré partielle, à valider et compléter avec des locuteurs natifs.

4. Vérifiabilité. Toutes ces propriétés sont rejouables par le jury : « npm test » (10 tests e2e : serveur aveugle, intrus, révocation, rotation Megolm, expiration, TOTP), « node scripts/inspecter_db.js "phrase secrète" », et les épreuves en direct depuis l'interface d'administration. Les tests constituent la preuve d'acceptation du socle de sécurité.